

ASSESSMENT REPORT

# NIS-2 Conformity Assessment

Directive (EU) 2022/2555

Demo Entity GmbH

AI-powered Analysis

|             |                                                  |
|-------------|--------------------------------------------------|
| ENTITY      | Demo Entity GmbH                                 |
| STANDARD    | NIS2                                             |
| REPORT TYPE | Internal Audit & Compliance Readiness Assessment |
| DATE        | 07 June 2026                                     |
| PREPARED BY | Inside the Box                                   |
| STATUS      | CONFIDENTIAL                                     |

---

# Table of Contents

1 Executive Summary .....  
2 Subject and Scope .....  
3 Assessment Principles .....  
4 Individual Findings .....  
5 Complete Control Matrix .....  
6 Risk Landscape .....  
7 Recommendations and Roadmap .....  
9 Conclusion .....  
Appendix A Working Papers & Traceability .....

lightspeedconsulting.ai

# 1 Executive Summary



COMPLIANCE DISTRIBUTION

VERDICT OVERVIEW



## Management Attention Index

Source: Deterministic Assessment Engine

Management Attention Index Critical (Critical 1 · High 1 · Medium 1 · Low 0)

KEY DRIVERS

% 1 critical risk(s)

% 2 mandatory control gap(s)

% 1 high risk(s)

% Readiness 82%

## Audit Readiness

Source: Deterministic Assessment Engine

Readiness (overall) Developing · 55%

Documentation Limited · 8%

1/12 controls backed by documented evidence (policy/procedure/document/audit report).

Operational Strong · 82%

Effectiveness of implemented controls (weighted compliance score).

Governance Strong · 100%

Average of governance-related categories (2).

Evidence Limited · 31%

12/12 controls with evidence, weighted by evidence strength.

## Why This Matters

This section translates the assessment results into business language for executives, board members and management teams. It frames the findings in terms of business impact, regulatory exposure, operational consequences, financial implications and strategic priorities — not just a score.

- %, Business impact — how gaps affect day-to-day operations and service delivery.
- %, Regulatory exposure — where the organisation falls short of mandatory obligations.
- %, Operational consequences — the risks that materialise if gaps remain unaddressed.
- %, Financial implications — potential cost of incidents, penalties and remediation.
- %, Strategic priorities — what management should focus on first to reduce exposure.

---

## 2 Subject and Scope

*The following section documents the intake data captured for the assessed entity. These form the basis of the rule-based assessment.*

|                                                     |                                                                                                                                                                                                                                                                                                     |
|-----------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>ENTITY</b>                                       | Demo Entity GmbH                                                                                                                                                                                                                                                                                    |
| <b>ENTITY NAME</b>                                  | Acme Utilities GmbH                                                                                                                                                                                                                                                                                 |
| <b>SECTOR(S)</b>                                    | Energy, Water                                                                                                                                                                                                                                                                                       |
| <b>CLASSIFICATION</b>                               | Essential entity                                                                                                                                                                                                                                                                                    |
| <b>DESCRIPTION OF OPERATIONS &amp; IT LANDSCAPE</b> | Regional energy and water utility with approx. 850 employees. Operates electricity, gas and water distribution networks, SCADA / control systems and a customer portal. On-premises data centre plus Microsoft 365 cloud. Critical systems: network control centre, billing system (SAP IS-U), GIS. |
| <b>KEY THIRD PARTIES</b>                            | Cloud provider, Software vendors, OT/equipment vendors                                                                                                                                                                                                                                              |
| <b>ESTABLISHED ROLES</b>                            | Management involved, CISO / IT security, DPO, Risk management                                                                                                                                                                                                                                       |
| <b>KNOWN WEAKNESSES / OPEN POINTS</b>               | No consistent MFA for administrative access in OT. BCM plan exists, but no full recovery test since 2023. Supplier contracts lack uniform security clauses. Vulnerability scans only in IT, not OT.                                                                                                 |
| <b>MEASURES PER ART. 21</b>                         | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits                                                                                                     |

---

## 3 Assessment Principles

The assessment follows an audit-safe, three-layer model: the compliance decision (pass / partial / gap) is derived strictly from the intake answers by deterministic rules. No finding is invented by the AI. Risks are derived deterministically from the gaps. The AI is used solely for the explanatory analysis layer.

## How This Assessment Was Produced

- %, Assessment responses were collected through structured intake.
- %, Compliance status was determined through deterministic assessment logic.
- %, Risks were derived from the identified gaps.
- %, AI generated explanatory insights, root cause analysis, clustering, management themes and roadmap recommendations.
- %, AI did not create, modify or override findings, risks, evidence or compliance results.

lightspeedconsulting.ai

---

## 4 Individual Findings

Source: Deterministic Assessment Engine

*Each requirement was assessed against the captured evidence using deterministic rules. Gaps and partial compliance are accompanied by concrete remediation recommendations.*

### 4.1 A20-1 — Management accountability & training

Article: Art. 20

PASS

#### EVIDENCE / OBSERVATION

Evidenced: Management involved, Training & awareness.

---

### 4.2 A21-1 — Risk analysis & security policies

Article: Art. 21(2)(a)

PASS

#### EVIDENCE / OBSERVATION

Evidenced: Risk analysis & security policies, Risk management.

---

### 4.3 A21-2 — Incident handling

Article: Art. 21(2)(b)

PASS

#### EVIDENCE / OBSERVATION

Evidenced: Incident handling.

---

### 4.4 A21-3 — Business continuity & backup

Article: Art. 21(2)(c)

PASS

#### EVIDENCE / OBSERVATION

Evidenced: Business continuity / backup.

---

### 4.5 A21-4 — Supply chain security

Article: Art. 21(2)(d)

FAIL

#### EVIDENCE / OBSERVATION

No evidence provided in the intake data.

#### IDENTIFIED GAP

Not evidenced: Supply chain security.

---

---

**RECOMMENDED MEASURE**

Implement / evidence: Supply chain security.

---

**4.6 A21-5 — Security in acquisition, development & maintenance**

Article: Art. 21(2)(e)

**PASS****EVIDENCE / OBSERVATION**

Evidenced: Vulnerability & patch mgmt.

---

**4.7 A21-6 — Effectiveness assessment of measures**

Article: Art. 21(2)(f)

**PASS****EVIDENCE / OBSERVATION**

Evidenced: Effectiveness reviews / audits.

---

**4.8 A21-7 — Cyber hygiene & training**

Article: Art. 21(2)(g)

**PASS****EVIDENCE / OBSERVATION**

Evidenced: Training & awareness.

---

**4.9 A21-8 — Cryptography & encryption**

Article: Art. 21(2)(h)

**PASS****EVIDENCE / OBSERVATION**

Evidenced: Cryptography / encryption.

---

**4.10 A21-9 — HR security & access control**

Article: Art. 21(2)(i)

**PARTIAL****EVIDENCE / OBSERVATION**

Evidenced: DPO.

**RECOMMENDED MEASURE**

Implement / evidence: HR security & access control.

---



#### 4.11 A21-10 — MFA & secured communications

Article: Art. 21(2)(j)

FAIL

##### EVIDENCE / OBSERVATION

No evidence provided in the intake data.

##### IDENTIFIED GAP

Not evidenced: MFA & access control.

##### RECOMMENDED MEASURE

Implement / evidence: MFA & access control.

#### 4.12 A23-1 — Reporting obligations (24h/72h/1 month)

Article: Art. 23

PASS

##### EVIDENCE / OBSERVATION

Evidenced: Incident handling.

## 5 Complete Control Matrix

Complete, traceable overview of all assessed requirements with verdict.

| ID     | Article       | Topic                                  | Verdict |
|--------|---------------|----------------------------------------|---------|
| A20-1  | Art. 20       | Management accountability & training   | Pass    |
| A21-1  | Art. 21(2)(a) | Risk analysis & security policies      | Pass    |
| A21-2  | Art. 21(2)(b) | Incident handling                      | Pass    |
| A21-3  | Art. 21(2)(c) | Business continuity & backup           | Pass    |
| A21-4  | Art. 21(2)(d) | Supply chain security                  | Gap     |
| A21-5  | Art. 21(2)(e) | Security in acquisition, development & | Pass    |
| A21-6  | Art. 21(2)(f) | Effectiveness assessment of measures   | Pass    |
| A21-7  | Art. 21(2)(g) | Cyber hygiene & training               | Pass    |
| A21-8  | Art. 21(2)(h) | Cryptography & encryption              | Pass    |
| A21-9  | Art. 21(2)(i) | HR security & access control           | Partial |
| A21-10 | Art. 21(2)(j) | MFA & secured communications           | Gap     |
| A23-1  | Art. 23       | Reporting obligations (24h/72h/1 month | Pass    |

### Evidence Strength Overview

Source: Deterministic Assessment Engine

Informational overview of the strength of evidence supporting the assessment. It does not affect scoring or compliance status.

|             |          |
|-------------|----------|
| Very high   | 1 (8%)   |
| High        | 0 (0%)   |
| Medium      | 0 (0%)   |
| Low         | 11 (92%) |
| No evidence | 0 (0%)   |

## 6 Risk Landscape

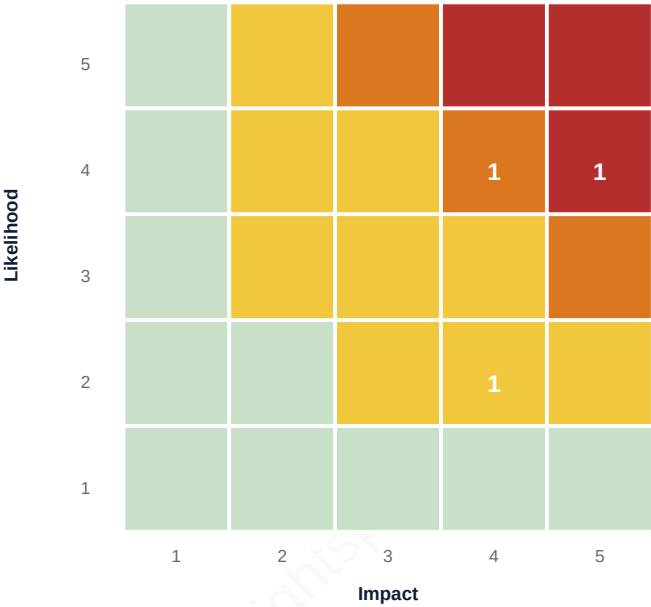
Source: Deterministic Risk Engine

The following risks were derived deterministically from the identified gaps (likelihood × impact).

### RISK DISTRIBUTION



### RISK HEATMAP



- R3** **FAIL** Efficiency in: MFA & secured communications (Impact 5 × Likelihood 4 = 20)
- R1** **FAIL** Efficiency in: Supply chain security (Impact 4 × Likelihood 4 = 16)
- R2** **PARTIAL** Efficiency in: HR security & access control (Impact 4 × Likelihood 2 = 8)

---

## 7 Recommendations and Roadmap

*Prioritised remediation plan, derived from the gaps and risks.*

### **Implement / evidence: Supply chain security.**

Critical · 0–1 month · Procurement / vendor mgmt  
Direct regulatory & operational exposure

### **Implement / evidence: MFA & access control.**

Critical · 0–1 month · IT security  
Direct regulatory & operational exposure

### **Implement / evidence: HR security & access control.**

Medium · 3–6 months · IT security / HR  
Moderate residual risk

## Remediation Roadmap

### PHASE 0-3 MONTHS

- %, Critical — Implement / evidence: Supply chain security.
- %, Critical — Implement / evidence: MFA & access control.

### PHASE 3-6 MONTHS

- %, Medium — Implement / evidence: HR security & access control.

## 9 Conclusion

Demo Entity GmbH: 82% — 9 Passed, 1 Partial, 2 Gaps.

This report does not constitute a formal certification and does not replace assessment by a recognised authority. The compliance assessment is based on the information provided during intake.

### REPORT METADATA

|                   |                                                  |
|-------------------|--------------------------------------------------|
| Assessment ID     | NIS2-MQ3S9R7Q                                    |
| Report Title      | Internal Audit & Compliance Readiness Assessment |
| Report Version    | 1.0.0                                            |
| Generated         | 07/06/2026, 12:53:53                             |
| Assessment Engine | 1.0.0                                            |
| AI Insight Engine | 1.0.0                                            |

# Working Papers & Assessment Traceability

Source: Deterministic Assessment Engine

For every requirement this working paper records exactly why it was assessed as Pass, Partial or Gap: each assessment question with the response given, the evidence recorded (type, name, source and strength), the deterministic rule applied, the generated risk and the AI sections that referenced the requirement. No assessment result is a black box.

## 1. A20-1 — Management accountability & training

Article: Art. 20 · Rule ID: A20-1-RULE

PASS

### ASSESSMENT QUESTION

Has the organization implemented and evidenced "Management accountability & training" as required by Art. 20?

### ASSESSMENT QUESTIONS & RESPONSES

|          |                                                                                                                                                                                                 |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Question | Established roles                                                                                                                                                                               |
| Answer   | Management involved, CISO / IT security, DPO, Risk management                                                                                                                                   |
| Question | Measures per Art. 21                                                                                                                                                                            |
| Answer   | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Comment  | Evidenced: Management involved, Training & awareness.                                                                                                                                           |

### EVIDENCE MANAGEMENT

|                   |                                                  |
|-------------------|--------------------------------------------------|
| Evidence Type     | Statement                                        |
| Evidence Name     | Management accountability & training — Statement |
| Evidence Source   | Self-assessment (intake)                         |
| Evidence Strength | Low                                              |

### EVIDENCE DESCRIPTION

Evidenced: Management involved, Training & awareness.

### ASSESSMENT RULE (DETERMINISTIC)

|                      |                                       |         |
|----------------------|---------------------------------------|---------|
| %,                   | IF Management involved !'             | Pass    |
| %,                   | IF ANY OF [ Training & awareness ] !' | Partial |
| %,                   | ELSE !'                               | Gap     |
| Deterministic Result | Pass                                  |         |

### RISK TRACEABILITY

No risk generated (requirement passed).

### AI TRACEABILITY

|                             |                                                                 |
|-----------------------------|-----------------------------------------------------------------|
| Referenced by AI            | No                                                              |
| <b>AUDIT TRAIL METADATA</b> |                                                                 |
| Assessment ID               | NIS2-MQ3S9R7Q                                                   |
| Assessment Version          | 1.0.0                                                           |
| Requirement ID              | A20-1                                                           |
| Rule ID                     | A20-1-RULE                                                      |
| Assessor                    | Inside the Box (rule-based assessment engine)                   |
| Source System               | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp                   | 07/06/2026, 12:53:53                                            |

2. A21-1 — Risk analysis & security policies

Article: Art. 21(2)(a) · Rule ID: A21-1-RULE

|                                                                                                                  |                                                                                                                                                                                                 |
|------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div>PASS</div>                                                                                                  |                                                                                                                                                                                                 |
| <b>ASSESSMENT QUESTION</b>                                                                                       |                                                                                                                                                                                                 |
| Has the organization implemented and evidenced "Risk analysis & security policies" as required by Art. 21(2)(a)? |                                                                                                                                                                                                 |
| <b>ASSESSMENT QUESTIONS &amp; RESPONSES</b>                                                                      |                                                                                                                                                                                                 |
| Question                                                                                                         | Measures per Art. 21                                                                                                                                                                            |
| Answer                                                                                                           | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Question                                                                                                         | Established roles                                                                                                                                                                               |
| Answer                                                                                                           | Management involved, CISO / IT security, DPO, Risk management                                                                                                                                   |
| Comment                                                                                                          | Evidenced: Risk analysis & security policies, Risk management.                                                                                                                                  |
| <b>EVIDENCE MANAGEMENT</b>                                                                                       |                                                                                                                                                                                                 |
| Evidence Type                                                                                                    | Statement                                                                                                                                                                                       |
| Evidence Name                                                                                                    | Risk analysis & security policies — Statement                                                                                                                                                   |
| Evidence Source                                                                                                  | Self-assessment (intake)                                                                                                                                                                        |
| Evidence Strength                                                                                                | Low                                                                                                                                                                                             |
| <b>EVIDENCE DESCRIPTION</b>                                                                                      |                                                                                                                                                                                                 |
| Evidenced: Risk analysis & security policies, Risk management.                                                   |                                                                                                                                                                                                 |
| <b>ASSESSMENT RULE (DETERMINISTIC)</b>                                                                           |                                                                                                                                                                                                 |
| %, IF Risk analysis & security policies!' Pass                                                                   |                                                                                                                                                                                                 |

|                      |                                          |
|----------------------|------------------------------------------|
| %,                   | IF ANY OF [ Risk management ] !' Partial |
| %,                   | ELSE !' Gap                              |
| Deterministic Result | Pass                                     |

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

|                  |    |
|------------------|----|
| Referenced by AI | No |
|------------------|----|

AUDIT TRAIL METADATA

|                    |                                                                 |
|--------------------|-----------------------------------------------------------------|
| Assessment ID      | NIS2-MQ3S9R7Q                                                   |
| Assessment Version | 1.0.0                                                           |
| Requirement ID     | A21-1                                                           |
| Rule ID            | A21-1-RULE                                                      |
| Assessor           | Inside the Box (rule-based assessment engine)                   |
| Source System      | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp          | 07/06/2026, 12:53:53                                            |

3. A21-2 — Incident handling

Article: Art. 21(2)(b) · Rule ID: A21-2-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Incident handling" as required by Art. 21(2)(b)?

ASSESSMENT QUESTIONS & RESPONSES

|          |                                                                                                                                                                                                 |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Question | Measures per Art. 21                                                                                                                                                                            |
| Answer   | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Question | Established roles                                                                                                                                                                               |
| Answer   | Management involved, CISO / IT security, DPO, Risk management                                                                                                                                   |
| Comment  | Evidenced: Incident handling.                                                                                                                                                                   |

EVIDENCE MANAGEMENT

|               |                               |
|---------------|-------------------------------|
| Evidence Type | Statement                     |
| Evidence Name | Incident handling — Statement |



|                                                                                                                                 |                                                                 |
|---------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| Evidence Source                                                                                                                 | Self-assessment (intake)                                        |
| Evidence Strength                                                                                                               | Low                                                             |
| <b>EVIDENCE DESCRIPTION</b>                                                                                                     |                                                                 |
| Evidenced: Incident handling.                                                                                                   |                                                                 |
| <b>ASSESSMENT RULE (DETERMINISTIC)</b>                                                                                          |                                                                 |
| <div>% IF Incident handling !' Pass</div> <div>% IF ANY OF [ Incident response team ] !' Partial</div> <div>% ELSE !' Gap</div> |                                                                 |
| Deterministic Result                                                                                                            | Pass                                                            |
| <b>RISK TRACEABILITY</b>                                                                                                        |                                                                 |
| No risk generated (requirement passed).                                                                                         |                                                                 |
| <b>AI TRACEABILITY</b>                                                                                                          |                                                                 |
| Referenced by AI                                                                                                                | No                                                              |
| <b>AUDIT TRAIL METADATA</b>                                                                                                     |                                                                 |
| Assessment ID                                                                                                                   | NIS2-MQ3S9R7Q                                                   |
| Assessment Version                                                                                                              | 1.0.0                                                           |
| Requirement ID                                                                                                                  | A21-2                                                           |
| Rule ID                                                                                                                         | A21-2-RULE                                                      |
| Assessor                                                                                                                        | Inside the Box (rule-based assessment engine)                   |
| Source System                                                                                                                   | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp                                                                                                                       | 07/06/2026, 12:53:53                                            |

4. A21-3 — Business continuity & backup

Article: Art. 21(2)(c) · Rule ID: A21-3-RULE

|                                                                                                             |                                                                                                                                                                                                 |
|-------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div>PASS</div>                                                                                             |                                                                                                                                                                                                 |
| <b>ASSESSMENT QUESTION</b>                                                                                  |                                                                                                                                                                                                 |
| Has the organization implemented and evidenced "Business continuity & backup" as required by Art. 21(2)(c)? |                                                                                                                                                                                                 |
| <b>ASSESSMENT QUESTIONS &amp; RESPONSES</b>                                                                 |                                                                                                                                                                                                 |
| Question                                                                                                    | Measures per Art. 21                                                                                                                                                                            |
| Answer                                                                                                      | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Comment                                                                                                     | Evidenced: Business continuity / backup.                                                                                                                                                        |
| <b>EVIDENCE MANAGEMENT</b>                                                                                  |                                                                                                                                                                                                 |

|                   |                                          |
|-------------------|------------------------------------------|
| Evidence Type     | Statement                                |
| Evidence Name     | Business continuity & backup — Statement |
| Evidence Source   | Self-assessment (intake)                 |
| Evidence Strength | Low                                      |

EVIDENCE DESCRIPTION

Evidenced: Business continuity / backup.

ASSESSMENT RULE (DETERMINISTIC)

|                      |                                                |         |
|----------------------|------------------------------------------------|---------|
| %,                   | IF Business continuity / backup !'             | Pass    |
| %,                   | IF SOME OF [ Business continuity / backup ] !' | Partial |
| %,                   | ELSE !'                                        | Gap     |
| Deterministic Result | Pass                                           |         |

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

|                  |    |
|------------------|----|
| Referenced by AI | No |
|------------------|----|

AUDIT TRAIL METADATA

|                    |                                                                 |
|--------------------|-----------------------------------------------------------------|
| Assessment ID      | NIS2-MQ3S9R7Q                                                   |
| Assessment Version | 1.0.0                                                           |
| Requirement ID     | A21-3                                                           |
| Rule ID            | A21-3-RULE                                                      |
| Assessor           | Inside the Box (rule-based assessment engine)                   |
| Source System      | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp          | 07/06/2026, 12:53:53                                            |

5. A21-4 — Supply chain security

Article: Art. 21(2)(d) · Rule ID: A21-4-RULE

FAIL

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Supply chain security" as required by Art. 21(2)(d)?

ASSESSMENT QUESTIONS & RESPONSES

|          |                                                                                                                                                                                                 |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Question | Measures per Art. 21                                                                                                                                                                            |
| Answer   | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Comment  | No evidence provided in the intake data.                                                                                                                                                        |

EVIDENCE MANAGEMENT

|                   |                                   |
|-------------------|-----------------------------------|
| Evidence Type     | Statement                         |
| Evidence Name     | Supply chain security — Statement |
| Evidence Source   | Self-assessment (intake)          |
| Evidence Strength | Low                               |

EVIDENCE DESCRIPTION

No evidence provided in the intake data.

ASSESSMENT RULE (DETERMINISTIC)

|                      |                                         |         |
|----------------------|-----------------------------------------|---------|
| %,                   | IF Supply chain security !'             | Pass    |
| %,                   | IF SOME OF [ Supply chain security ] !' | Partial |
| %,                   | ELSE !'                                 | Gap     |
| Deterministic Result | Gap                                     |         |

RISK TRACEABILITY

|                |                                     |
|----------------|-------------------------------------|
| Generated Risk | R1                                  |
| Risk Formula   | Likelihood 4 × Impact 4 = 16 (High) |

AI TRACEABILITY

|                  |    |
|------------------|----|
| Referenced by AI | No |
|------------------|----|

AUDIT TRAIL METADATA

|                    |               |
|--------------------|---------------|
| Assessment ID      | NIS2-MQ3S9R7Q |
| Assessment Version | 1.0.0         |
| Requirement ID     | A21-4         |
| Rule ID            | A21-4-RULE    |

|               |                                                                 |
|---------------|-----------------------------------------------------------------|
| Assessor      | Inside the Box (rule-based assessment engine)                   |
| Source System | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp     | 07/06/2026, 12:53:53                                            |

6. A21-5 — Security in acquisition, development & maintenance

Article: Art. 21(2)(e) · Rule ID: A21-5-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Security in acquisition, development & maintenance" as required by Art. 21(2)(e)?

ASSESSMENT QUESTIONS & RESPONSES

|          |                                                                                                                                                                                                 |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Question | Measures per Art. 21                                                                                                                                                                            |
| Answer   | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Comment  | Evidenced: Vulnerability & patch mgmt.                                                                                                                                                          |

EVIDENCE MANAGEMENT

|                   |                                                                |
|-------------------|----------------------------------------------------------------|
| Evidence Type     | Statement                                                      |
| Evidence Name     | Security in acquisition, development & maintenance — Statement |
| Evidence Source   | Self-assessment (intake)                                       |
| Evidence Strength | Low                                                            |

EVIDENCE DESCRIPTION

Evidenced: Vulnerability & patch mgmt.

ASSESSMENT RULE (DETERMINISTIC)

% , IF Vulnerability & patch mgmt !' Pass

% , IF SOME OF [ Vulnerability & patch mgmt ] !' Partial

% , ELSE !' Gap

Deterministic ResultPass

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

|                  |    |
|------------------|----|
| Referenced by AI | No |
|------------------|----|

AUDIT TRAIL METADATA

|               |               |
|---------------|---------------|
| Assessment ID | NIS2-MQ3S9R7Q |
|---------------|---------------|

|                    |                                                                 |
|--------------------|-----------------------------------------------------------------|
| Assessment Version | 1.0.0                                                           |
| Requirement ID     | A21-5                                                           |
| Rule ID            | A21-5-RULE                                                      |
| Assessor           | Inside the Box (rule-based assessment engine)                   |
| Source System      | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp          | 07/06/2026, 12:53:53                                            |

7. A21-6 — Effectiveness assessment of measures

Article: Art. 21(2)(f) · Rule ID: A21-6-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Effectiveness assessment of measures" as required by Art. 21(2)(f)?

ASSESSMENT QUESTIONS & RESPONSES

|          |                                                                                                                                                                                                 |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Question | Measures per Art. 21                                                                                                                                                                            |
| Answer   | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Comment  | Evidenced: Effectiveness reviews / audits.                                                                                                                                                      |

EVIDENCE MANAGEMENT

|                   |                                                        |
|-------------------|--------------------------------------------------------|
| Evidence Type     | Audit report                                           |
| Evidence Name     | Effectiveness assessment of measures — Audit report    |
| Evidence Source   | External audit/assurance report (referenced in intake) |
| Evidence Strength | Very high                                              |

EVIDENCE DESCRIPTION

Evidenced: Effectiveness reviews / audits.

ASSESSMENT RULE (DETERMINISTIC)

%, IF Effectiveness reviews / audits !' Pass

%, IF SOME OF [ Effectiveness reviews / audits ] !' Partial

%, ELSE !' Gap

Deterministic Result

Pass

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

|                             |                                                                 |
|-----------------------------|-----------------------------------------------------------------|
| Referenced by AI            | No                                                              |
| <b>AUDIT TRAIL METADATA</b> |                                                                 |
| Assessment ID               | NIS2-MQ3S9R7Q                                                   |
| Assessment Version          | 1.0.0                                                           |
| Requirement ID              | A21-6                                                           |
| Rule ID                     | A21-6-RULE                                                      |
| Assessor                    | Inside the Box (rule-based assessment engine)                   |
| Source System               | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp                   | 07/06/2026, 12:53:53                                            |

8. A21-7 — Cyber hygiene & training

Article: Art. 21(2)(g) · Rule ID: A21-7-RULE

|                                                                                                                                                                                                        |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| PASS                                                                                                                                                                                                   |
| <b>ASSESSMENT QUESTION</b>                                                                                                                                                                             |
| Has the organization implemented and evidenced "Cyber hygiene & training" as required by Art. 21(2)(g)?                                                                                                |
| <b>ASSESSMENT QUESTIONS &amp; RESPONSES</b>                                                                                                                                                            |
| Question Measures per Art. 21                                                                                                                                                                          |
| Answer Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Comment Evidenced: Training & awareness.                                                                                                                                                               |
| <b>EVIDENCE MANAGEMENT</b>                                                                                                                                                                             |
| Evidence Type Statement                                                                                                                                                                                |
| Evidence Name Cyber hygiene & training — Statement                                                                                                                                                     |
| Evidence Source Self-assessment (intake)                                                                                                                                                               |
| Evidence Strength Low                                                                                                                                                                                  |
| <b>EVIDENCE DESCRIPTION</b>                                                                                                                                                                            |
| Evidenced: Training & awareness.                                                                                                                                                                       |
| <b>ASSESSMENT RULE (DETERMINISTIC)</b>                                                                                                                                                                 |
| %, IF Training & awareness !' Pass                                                                                                                                                                     |
| %, IF SOME OF [ Training & awareness ] !' Partial                                                                                                                                                      |
| %, ELSE !' Gap                                                                                                                                                                                         |
| Deterministic Result Pass                                                                                                                                                                              |

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

Referenced by AI    No

AUDIT TRAIL METADATA

Assessment ID    NIS2-MQ3S9R7Q

Assessment Version    1.0.0

Requirement ID    A21-7

Rule ID    A21-7-RULE

Assessor    Inside the Box (rule-based assessment engine)

Source System    Inside the Box — Internal Audit & Compliance Readiness Platform

Timestamp    07/06/2026, 12:53:53

9. A21-8 — Cryptography & encryption

Article: Art. 21(2)(h) · Rule ID: A21-8-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Cryptography & encryption" as required by Art. 21(2)(h)?

ASSESSMENT QUESTIONS & RESPONSES

Question    Measures per Art. 21

Answer    Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits

Comment    Evidenced: Cryptography / encryption.

EVIDENCE MANAGEMENT

Evidence Type    Statement

Evidence Name    Cryptography & encryption — Statement

Evidence Source    Self-assessment (intake)

Evidence Strength    Low

EVIDENCE DESCRIPTION

Evidenced: Cryptography / encryption.

ASSESSMENT RULE (DETERMINISTIC)

%, IF Cryptography / encryption !' Pass

|                                                        |                                                                 |
|--------------------------------------------------------|-----------------------------------------------------------------|
| %, IF SOME OF [ Cryptography / encryption ] !' Partial |                                                                 |
| %, ELSE !' Gap                                         |                                                                 |
| Deterministic Result                                   | Pass                                                            |
| <b>RISK TRACEABILITY</b>                               |                                                                 |
| No risk generated (requirement passed).                |                                                                 |
| <b>AI TRACEABILITY</b>                                 |                                                                 |
| Referenced by AI                                       | No                                                              |
| <b>AUDIT TRAIL METADATA</b>                            |                                                                 |
| Assessment ID                                          | NIS2-MQ3S9R7Q                                                   |
| Assessment Version                                     | 1.0.0                                                           |
| Requirement ID                                         | A21-8                                                           |
| Rule ID                                                | A21-8-RULE                                                      |
| Assessor                                               | Inside the Box (rule-based assessment engine)                   |
| Source System                                          | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp                                              | 07/06/2026, 12:53:53                                            |

10. A21-9 — HR security & access control

Article: Art. 21(2)(i) · Rule ID: A21-9-RULE

|                                                                                                             |                                                                                                                                                                                                 |
|-------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| PARTIAL                                                                                                     |                                                                                                                                                                                                 |
| <b>ASSESSMENT QUESTION</b>                                                                                  |                                                                                                                                                                                                 |
| Has the organization implemented and evidenced "HR security & access control" as required by Art. 21(2)(i)? |                                                                                                                                                                                                 |
| <b>ASSESSMENT QUESTIONS &amp; RESPONSES</b>                                                                 |                                                                                                                                                                                                 |
| Question                                                                                                    | Measures per Art. 21                                                                                                                                                                            |
| Answer                                                                                                      | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Question                                                                                                    | Established roles                                                                                                                                                                               |
| Answer                                                                                                      | Management involved, CISO / IT security, DPO, Risk management                                                                                                                                   |
| Comment                                                                                                     | Evidenced: DPO.                                                                                                                                                                                 |
| <b>EVIDENCE MANAGEMENT</b>                                                                                  |                                                                                                                                                                                                 |
| Evidence Type                                                                                               | Statement                                                                                                                                                                                       |
| Evidence Name                                                                                               | HR security & access control — Statement                                                                                                                                                        |



|                                                         |                                                                 |
|---------------------------------------------------------|-----------------------------------------------------------------|
| Evidence Source                                         | Self-assessment (intake)                                        |
| Evidence Strength                                       | Low                                                             |
| <b>EVIDENCE DESCRIPTION</b>                             |                                                                 |
| Evidenced: DPO.                                         |                                                                 |
| <b>ASSESSMENT RULE (DETERMINISTIC)</b>                  |                                                                 |
| % , IF ANY OF [ MFA & access control , DPO ] !' Partial |                                                                 |
| % , ELSE !' Gap                                         |                                                                 |
| Deterministic Result                                    | Partial                                                         |
| <b>RISK TRACEABILITY</b>                                |                                                                 |
| Generated Risk                                          | R2                                                              |
| Risk Formula                                            | Likelihood 2 × Impact 4 = 8 (Medium)                            |
| <b>AI TRACEABILITY</b>                                  |                                                                 |
| Referenced by AI                                        | No                                                              |
| <b>AUDIT TRAIL METADATA</b>                             |                                                                 |
| Assessment ID                                           | NIS2-MQ3S9R7Q                                                   |
| Assessment Version                                      | 1.0.0                                                           |
| Requirement ID                                          | A21-9                                                           |
| Rule ID                                                 | A21-9-RULE                                                      |
| Assessor                                                | Inside the Box (rule-based assessment engine)                   |
| Source System                                           | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp                                               | 07/06/2026, 12:53:53                                            |

11. A21-10 — MFA & secured communications

Article: Art. 21(2)(j) · Rule ID: A21-10-RULE

FAIL

ASSESSMENT QUESTION

Has the organization implemented and evidenced "MFA & secured communications" as required by Art. 21(2)(j)?

ASSESSMENT QUESTIONS & RESPONSES

|          |                                                                                                                                                                                                 |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Question | Measures per Art. 21                                                                                                                                                                            |
| Answer   | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Comment  | No evidence provided in the intake data.                                                                                                                                                        |

EVIDENCE MANAGEMENT

|                   |                                          |
|-------------------|------------------------------------------|
| Evidence Type     | Statement                                |
| Evidence Name     | MFA & secured communications — Statement |
| Evidence Source   | Self-assessment (intake)                 |
| Evidence Strength | Low                                      |

EVIDENCE DESCRIPTION

No evidence provided in the intake data.

ASSESSMENT RULE (DETERMINISTIC)

|                      |      |      |    |        |         |   |        |         |   |   |   |         |
|----------------------|------|------|----|--------|---------|---|--------|---------|---|---|---|---------|
| %,                   | IF   | MFA  | &  | access | control | ! | '      | Pass    |   |   |   |         |
| %,                   | IF   | SOME | OF | [      | MFA     | & | access | control | ] | ! | ' | Partial |
| %,                   | ELSE | !    | '  | Gap    |         |   |        |         |   |   |   |         |
| Deterministic Result |      | Gap  |    |        |         |   |        |         |   |   |   |         |

RISK TRACEABILITY

|                |                                         |
|----------------|-----------------------------------------|
| Generated Risk | R3                                      |
| Risk Formula   | Likelihood 4 × Impact 5 = 20 (Critical) |

AI TRACEABILITY

|                  |    |
|------------------|----|
| Referenced by AI | No |
|------------------|----|

AUDIT TRAIL METADATA

|                    |                                                                 |
|--------------------|-----------------------------------------------------------------|
| Assessment ID      | NIS2-MQ3S9R7Q                                                   |
| Assessment Version | 1.0.0                                                           |
| Requirement ID     | A21-10                                                          |
| Rule ID            | A21-10-RULE                                                     |
| Assessor           | Inside the Box (rule-based assessment engine)                   |
| Source System      | Inside the Box — Internal Audit & Compliance Readiness Platform |
| Timestamp          | 07/06/2026, 12:53:53                                            |

12. A23-1 — Reporting obligations (24h/72h/1 month)

Article: Art. 23 · Rule ID: A23-1-RULE

PASS

ASSESSMENT QUESTION

Has the organization implemented and evidenced "Reporting obligations (24h/72h/1 month)" as required by Art. 23?

ASSESSMENT QUESTIONS & RESPONSES

|          |                                                                                                                                                                                                 |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Question | Measures per Art. 21                                                                                                                                                                            |
| Answer   | Risk analysis & security policies, Incident handling, Business continuity / backup, Vulnerability & patch mgmt, Cryptography / encryption, Training & awareness, Effectiveness reviews / audits |
| Question | Established roles                                                                                                                                                                               |
| Answer   | Management involved, CISO / IT security, DPO, Risk management                                                                                                                                   |
| Comment  | Evidenced: Incident handling.                                                                                                                                                                   |

EVIDENCE MANAGEMENT

|                   |                                                     |
|-------------------|-----------------------------------------------------|
| Evidence Type     | Statement                                           |
| Evidence Name     | Reporting obligations (24h/72h/1 month) — Statement |
| Evidence Source   | Self-assessment (intake)                            |
| Evidence Strength | Low                                                 |

EVIDENCE DESCRIPTION

Evidenced: Incident handling.

ASSESSMENT RULE (DETERMINISTIC)

|                      |                                                 |
|----------------------|-------------------------------------------------|
| %,                   | IF Incident handling !' Pass                    |
| %,                   | IF ANY OF [ Incident response team ] !' Partial |
| %,                   | ELSE !' Gap                                     |
| Deterministic Result | Pass                                            |

RISK TRACEABILITY

No risk generated (requirement passed).

AI TRACEABILITY

|                  |    |
|------------------|----|
| Referenced by AI | No |
|------------------|----|

AUDIT TRAIL METADATA

|                    |               |
|--------------------|---------------|
| Assessment ID      | NIS2-MQ3S9R7Q |
| Assessment Version | 1.0.0         |
| Requirement ID     | A23-1         |

---

**Rule ID** A23-1-RULE

**Assessor** Inside the Box (rule-based assessment engine)

**Source System** Inside the Box — Internal Audit & Compliance Readiness Platform

**Timestamp** 07/06/2026, 12:53:53

---

## Evidence Register (Appendix)

Source: Deterministic Assessment Engine

Every evidence item mapped to its requirement, type, strength and assessment contribution.

| ID    | Req.   | Type         | Strength  | Result  |
|-------|--------|--------------|-----------|---------|
| E-001 | A20-1  | Statement    | Low       | Pass    |
| E-002 | A21-1  | Statement    | Low       | Pass    |
| E-003 | A21-2  | Statement    | Low       | Pass    |
| E-004 | A21-3  | Statement    | Low       | Pass    |
| E-005 | A21-4  | Statement    | Low       | Gap     |
| E-006 | A21-5  | Statement    | Low       | Pass    |
| E-007 | A21-6  | Audit report | Very high | Pass    |
| E-008 | A21-7  | Statement    | Low       | Pass    |
| E-009 | A21-8  | Statement    | Low       | Pass    |
| E-010 | A21-9  | Statement    | Low       | Partial |
| E-011 | A21-10 | Statement    | Low       | Gap     |
| E-012 | A23-1  | Statement    | Low       | Pass    |

### E-001 — A20-1

**Requirement** Management accountability & training

**Type** Statement

**Strength** Low

**Used For** Management accountability & training

**Result Contribution** Pass

#### DESCRIPTION

Evidenced: Management involved, Training & awareness.

### E-002 — A21-1

**Requirement** Risk analysis & security policies

**Type** Statement

**Strength** Low

**Used For** Risk analysis & security policies

**Result Contribution** Pass

#### DESCRIPTION

Evidenced: Risk analysis & security policies, Risk management.

**E-003 — A21-2**

**Requirement** Incident handling

**Type** Statement

**Strength** Low

**Used For** Incident handling

**Result Contribution** Pass

**DESCRIPTION**

Evidenced: Incident handling.

**E-004 — A21-3**

**Requirement** Business continuity & backup

**Type** Statement

**Strength** Low

**Used For** Business continuity & backup

**Result Contribution** Pass

**DESCRIPTION**

Evidenced: Business continuity / backup.

**E-005 — A21-4**

**Requirement** Supply chain security

**Type** Statement

**Strength** Low

**Used For** Supply chain security

**Result Contribution** Gap

**DESCRIPTION**

No evidence provided in the intake data.

**E-006 — A21-5**

**Requirement** Security in acquisition, development & maintenance

**Type** Statement

Strength Low

Used For Security in acquisition, development & maintenance

Result Contribution Pass

#### DESCRIPTION

Evidenced: Vulnerability & patch mgmt.

### E-007 — A21-6

Requirement Effectiveness assessment of measures

Type Audit report

Strength Very high

Used For Effectiveness assessment of measures

Result Contribution Pass

#### DESCRIPTION

Evidenced: Effectiveness reviews / audits.

### E-008 — A21-7

Requirement Cyber hygiene & training

Type Statement

Strength Low

Used For Cyber hygiene & training

Result Contribution Pass

#### DESCRIPTION

Evidenced: Training & awareness.

### E-009 — A21-8

Requirement Cryptography & encryption

Type Statement

Strength Low

Used For Cryptography & encryption

Result Contribution Pass

**DESCRIPTION**

Evidenced: Cryptography / encryption.

**E-010 — A21-9**

**Requirement** HR security & access control

**Type** Statement

**Strength** Low

**Used For** HR security & access control

**Result Contribution** Partial

**DESCRIPTION**

Evidenced: DPO.

**E-011 — A21-10**

**Requirement** MFA & secured communications

**Type** Statement

**Strength** Low

**Used For** MFA & secured communications

**Result Contribution** Gap

**DESCRIPTION**

No evidence provided in the intake data.

**E-012 — A23-1**

**Requirement** Reporting obligations (24h/72h/1 month)

**Type** Statement

**Strength** Low

**Used For** Reporting obligations (24h/72h/1 month)

**Result Contribution** Pass

**DESCRIPTION**

Evidenced: Incident handling.